PERTEMUAN PRAKTIKUM

Teknologi dan Tools Authentication & Authorization

Mengenali cara aplikasi memastikan siapa penggunanya dan sejauh mana ia boleh bertindak

Praktik Pemrograman Berbasis Web II · RPL24323

Agenda

Enam hal yang akan kita bahas

1. **Konsep authentication**
   Memastikan identitas pengguna
2. **Konsep authorization**
   Menentukan batas kewenangannya
3. **Session dan credential**
   Cara aplikasi mengingat pengguna
4. **Middleware**
   Penjaga di depan setiap halaman
5. **Tools dan framework pendukung**
   Pilihan paket yang tersedia
6. **Fungsi tools dalam pengelolaan akses**
   Apa yang dikerjakan paket tersebut

BAGIAN 1

Konsep Authentication

Bagaimana aplikasi memastikan bahwa pengguna benar-benar orang yang diakuinya.

Apa Itu Authentication?

Proses membuktikan identitas

Authentication adalah proses memverifikasi bahwa pengguna benar-benar orang yang ia klaim. Pertanyaannya sederhana: siapa Anda?

Tiga faktor autentikasi

SESUATU YANG DIKETAHUI

Kata sandi, PIN, jawaban pertanyaan keamanan.

SESUATU YANG DIMILIKI

Ponsel penerima kode, kartu akses, token perangkat keras.

SESUATU YANG MELEKAT

Sidik jari, pemindaian wajah, pola suara.

Menggabungkan dua faktor berbeda disebut two-factor authentication, dan jauh lebih sulit ditembus daripada kata sandi saja.

Alur Proses Login

Yang terjadi setelah tombol masuk ditekan

1

Pengiriman kredensial

Pengguna mengisi surel dan kata sandi, lalu mengirimkannya ke server.

2

Pencarian pengguna

Aplikasi mencari data pengguna yang cocok dengan surel tersebut.

3

Pencocokan sandi

Kata sandi yang dikirim dicocokkan dengan nilai acak yang tersimpan.

4

Pembuatan session

Bila cocok, server membuat session dan mengirim penandanya ke peramban.

5

Akses berikutnya

Peramban mengirim penanda itu pada setiap permintaan selanjutnya.

PENTING

Kata sandi tidak pernah dibandingkan apa adanya. Yang tersimpan di basis data adalah hasil pengacakan satu arah, dan yang dicocokkan adalah hasil pengacakan dari masukan pengguna.

BAGIAN 2

Konsep Authorization

Setelah tahu siapa penggunanya, aplikasi perlu tahu apa saja yang boleh ia lakukan.

Authentication vs Authorization

Dua hal berbeda yang sering tertukar

Aspek	Authentication	Authorization
Pertanyaan	Siapa Anda?	Apa yang boleh Anda lakukan?
Waktu terjadi	Di awal, saat pengguna masuk	Setiap kali pengguna mengakses sesuatu
Dasar penilaian	Kredensial yang dimiliki pengguna	Peran atau kepemilikan data
Bila gagal	Diarahkan ke halaman masuk	Muncul halaman 403 Forbidden
Contoh	Masuk dengan surel dan kata sandi	Hanya admin yang boleh menghapus data

Urutannya selalu tetap: autentikasi lebih dulu, otorisasi menyusul.

Tiga Model Pengaturan Hak Akses

Cara menentukan siapa boleh melakukan apa

BERBASIS PERAN

Role Based Access Control

Setiap pengguna diberi peran, misalnya admin, petugas, atau anggota. Hak akses melekat pada perannya, bukan pada orangnya. Paling umum dan paling mudah dikelola.

BERBASIS IZIN

Permission Based

Hak akses dirinci per aksi, misalnya boleh melihat laporan tetapi tidak boleh menghapusnya. Lebih luwes, tetapi lebih rumit dikelola.

BERBASIS KEPEMILIKAN

Ownership Based

Pengguna hanya boleh mengubah data miliknya sendiri. Sering dipakai bersamaan dengan dua model di atas.

Untuk proyek PjBL, model berbasis peran sudah memadai: cukup satu kolom peran pada tabel pengguna, lalu periksa nilainya sebelum menampilkan menu atau memproses aksi.

BAGIAN 3

Session dan Credential

Bagaimana aplikasi mengingat pengguna, dan bagaimana kata sandi disimpan dengan aman.

Credential dan Penyimpanan Kata Sandi

Aturan yang tidak boleh dilanggar

JANGAN

- Menyimpan kata sandi apa adanya di basis data
- Memakai enkripsi dua arah yang bisa dibalik
- Mengirim kata sandi lewat surel saat pengguna lupa
- Menampilkan kata sandi pada berkas log
- Membuat batas panjang maksimal yang terlalu pendek

LAKUKAN

- Simpan hasil pengacakan satu arah dengan bcrypt
- Biarkan framework menambahkan salt secara otomatis
- Kirim tautan atur ulang berbatas waktu saat lupa sandi
- Tetapkan panjang minimal dan periksa kekuatannya
- Batasi jumlah percobaan masuk yang gagal

Cara Kerja Session

Mengapa aplikasi masih mengenali Anda di halaman berikutnya

1

Session dibuat

Setelah login berhasil, server menyimpan data sesi dan memberinya penanda unik.

2

Penanda dikirim

Penanda itu disimpan peramban sebagai cookie, bukan data penggunanya.

3

Dikirim ulang

Setiap permintaan berikutnya membawa cookie tersebut secara otomatis.

4

Sesi diakhiri

Saat keluar atau melewati batas waktu, data sesi di server dihapus.

Tempat penyimpanan session

FILE Disimpan sebagai berkas di server. Bawaan dan cukup untuk aplikasi kecil.

DATABASE Disimpan pada tabel tersendiri. Cocok bila aplikasi berjalan di beberapa server.

CACHE Disimpan di memori seperti Redis. Paling cepat, perlu layanan tambahan.

BAGIAN 4

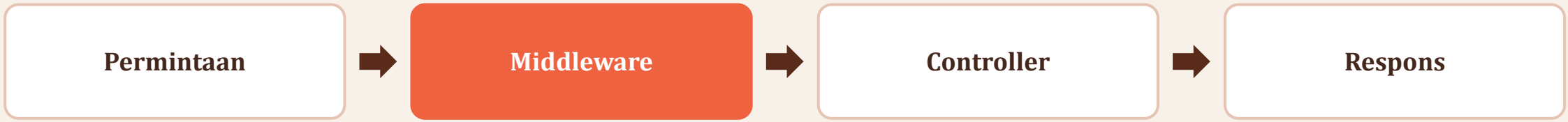
Middleware

Lapisan pemeriksa yang berdiri di antara permintaan pengguna dan kode Anda.

Middleware sebagai Penjaga Pintu

Posisinya dalam alur permintaan

Middleware adalah lapisan yang memeriksa setiap permintaan sebelum sampai ke Controller. Bila syaratnya tidak terpenuhi, permintaan dihentikan di sini.



auth Menolak pengguna yang belum masuk dan mengarahkannya ke halaman login.

guest Kebalikannya: menolak pengguna yang sudah masuk, dipakai pada halaman login.

verified Hanya meloloskan pengguna yang alamat surelnya sudah diverifikasi.

can Memeriksa kewenangan tertentu sebelum permintaan diteruskan.

Menerapkan dan Membuat Middleware

Tiga cara memasang, satu cara membuat

1 Pada satu route

Ditempelkan langsung ketika route didefinisikan. Cocok untuk halaman tunggal.

2 Pada kelompok route

Beberapa route dibungkus sekaligus. Paling praktis untuk area khusus admin.

3 Pada controller

Dipasang di konstruktor sehingga berlaku untuk seluruh method di dalamnya.

Membuat middleware sendiri

- Buat berkasnya: php artisan make:middleware CekPeranAdmin
- Tuliskan syaratnya di dalam method handle, lalu teruskan permintaan bila lolos.
- Daftarkan namanya agar dapat dipanggil dari route.
- Pasang pada route atau kelompok route yang memerlukannya.

BAGIAN 5

Tools dan Framework Pendukung

Paket siap pakai yang menghemat waktu Anda membangun sistem akses.

Paket Autentikasi pada Ekosistem Laravel

Enam pilihan resmi beserta peruntukannya

Breeze

Paket paling sederhana. Menyediakan registrasi, login, atur ulang sandi, dan verifikasi surel dengan tampilan Blade yang mudah disunting.

Jetstream

Lebih lengkap. Menambahkan autentikasi dua faktor, pengelolaan sesi perangkat, dan fitur tim.

Fortify

Hanya menyediakan sisi belakangnya tanpa tampilan. Dipakai bila antarmuka ingin dibangun sendiri.

Sanctum

Untuk autentikasi API berbasis token. Ringan dan paling umum dipakai untuk aplikasi ponsel atau SPA.

Passport

Penerapan OAuth2 penuh. Dipakai bila aplikasi lain perlu mengakses data atas nama pengguna.

Socialite

Untuk masuk melalui akun pihak ketiga seperti Google atau GitHub.

Memilih yang Sesuai Kebutuhan

Pertanyaan penuntun sebelum memasang paket

Aplikasi web biasa dengan halaman Blade	Breeze
Perlu autentikasi dua faktor dan fitur tim	Jetstream
Tampilan ingin dibangun sendiri dari nol	Fortify
Menyediakan API untuk aplikasi ponsel	Sanctum
Aplikasi pihak ketiga perlu izin akses pengguna	Passport
Ingin menyediakan masuk lewat akun Google	Socialite

Untuk proyek PjBL mata kuliah ini, Breeze adalah pilihan yang paling tepat.

BAGIAN 6

Fungsi Tools dalam Pengelolaan Akses

Apa saja yang sebenarnya dikerjakan paket-paket tersebut untuk Anda.

Enam Fungsi yang Ditangani Paket Autentikasi

Pekerjaan yang tidak perlu Anda tulis sendiri

1

Registrasi pengguna

Formulir pendaftaran, validasi, dan pengacakan kata sandi sebelum disimpan.

2

Proses masuk dan keluar

Pencocokan kredensial, pembuatan session, serta penghapusannya saat keluar.

3

Atur ulang kata sandi

Pengiriman tautan berbatas waktu ke surel pengguna beserta formulir penggantinya.

4

Verifikasi surel

Memastikan alamat surel benar-benar dimiliki pengguna sebelum akses penuh diberikan.

5

Pembatasan percobaan

Menahan sementara pengguna yang berulang kali gagal masuk.

6

Pemeriksaan kewenangan

Gate dan Policy untuk menentukan boleh tidaknya sebuah aksi dijalankan.

Praktik Baik Pengelolaan Akses

Hal yang tetap menjadi tanggung jawab Anda meski memakai paket siap pakai

Periksa di sisi server

Menyembunyikan tombol dari tampilan bukan pengamanan. Pemeriksaan tetap wajib dilakukan sebelum aksi diproses.

Terapkan hak akses seminimal mungkin

Beri pengguna kewenangan sebatas yang benar-benar diperlukan untuk pekerjaannya.

Jangan percayai identitas dari sisi klien

Peran pengguna dibaca dari basis data, bukan dari nilai yang dikirim peramban.

Lindungi seluruh route yang sensitif

Satu halaman yang terlewat sudah cukup untuk membuka seluruh data.

RANGKUMAN

Lima hal untuk dibawa pulang

1. Authentication menjawab siapa penggunanya; authorization menjawab apa yang boleh ia lakukan.
2. Kata sandi disimpan sebagai hasil pengacakan satu arah, tidak pernah apa adanya.
3. Session membuat aplikasi tetap mengenali pengguna tanpa meminta kredensial berulang kali.
4. Middleware adalah tempat paling tepat untuk memasang pemeriksaan akses.
5. Paket seperti Breeze menghemat waktu, tetapi keputusan siapa boleh apa tetap milik Anda.

Pada praktikum, kita terapkan langsung pada proyek PjBL kelompok.